SPECTEROPS
Creators of BloodHound

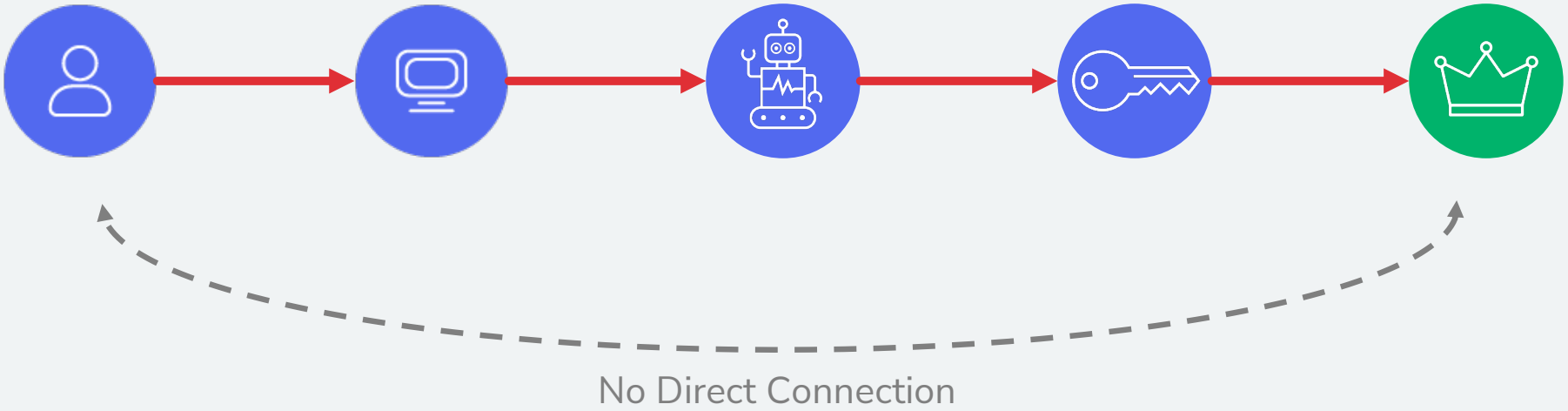
Attack Paths in Practice

Okta, GitHub, and Jamf with BloodHound Enterprise

Justin Kohler
Chief Product Officer

Jared Atkinson
Chief Technology Officer

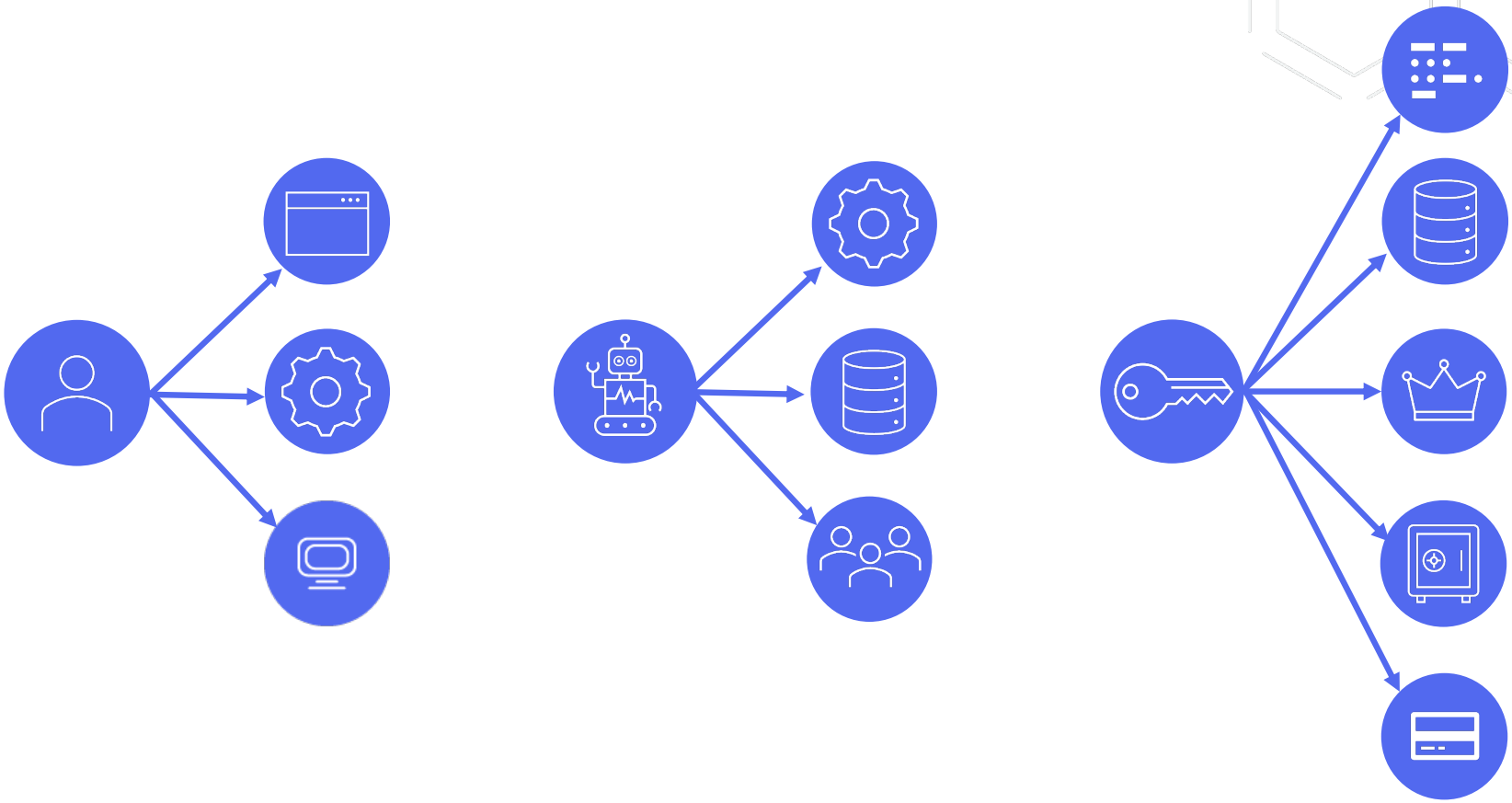
Attack paths are how privileges and behavior connect identities to control



SPECTEROPS

© Specter Ops, Inc.

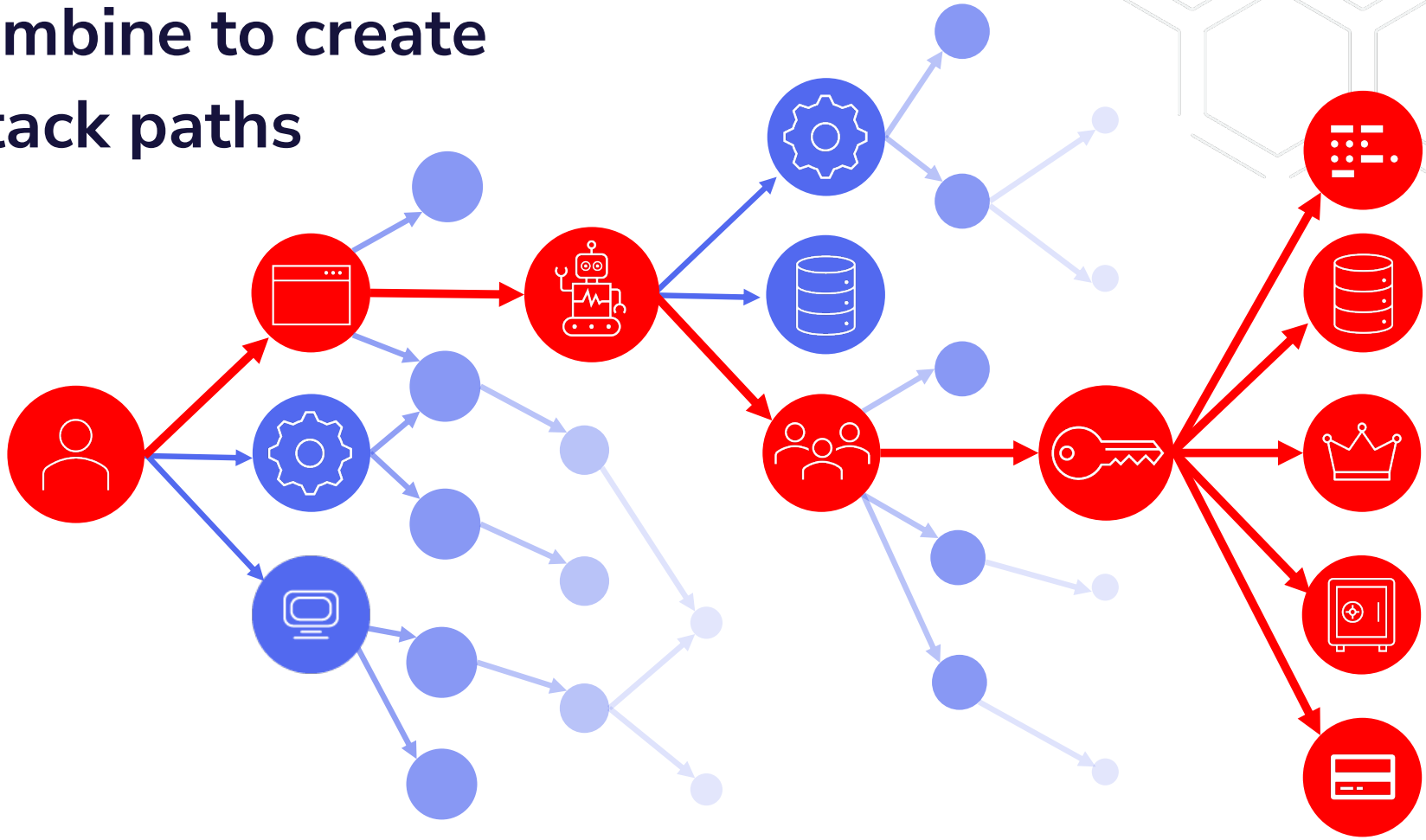
Benign, isolated identity configurations



SPECTEROPS

© Specter Ops, Inc.

Combine to create attack paths



SPECTEROPS

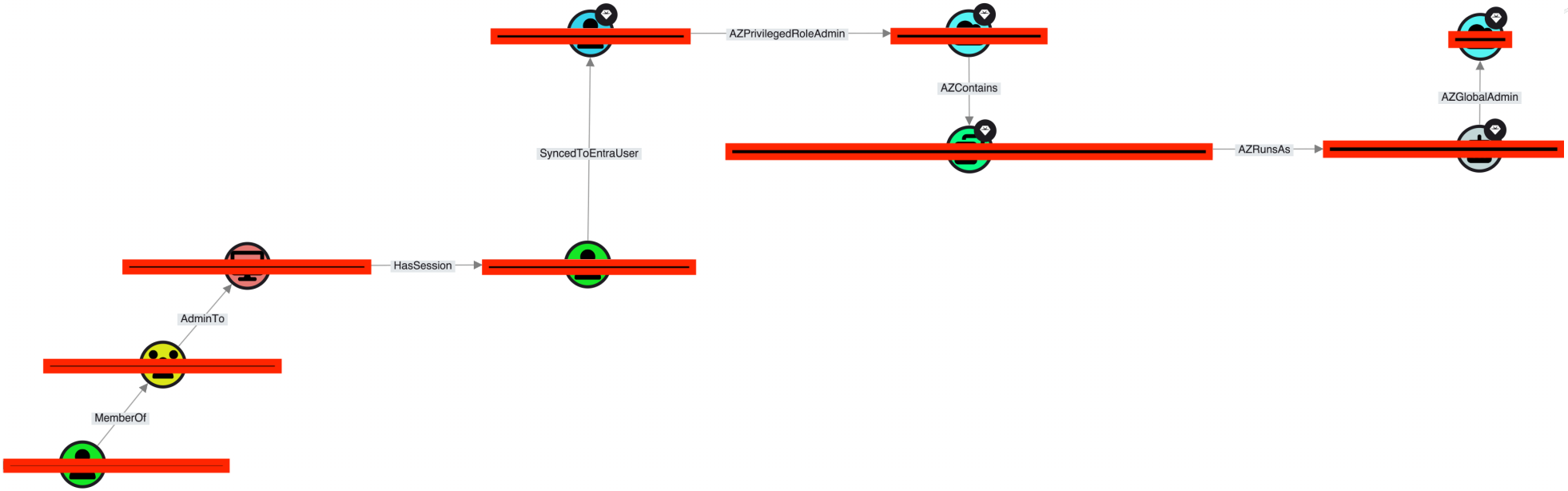
© Specter Ops, Inc.

From Bad to Ugly:
Cross-Platform Attack Paths

SPECTEROPS

© Specter Ops, Inc.

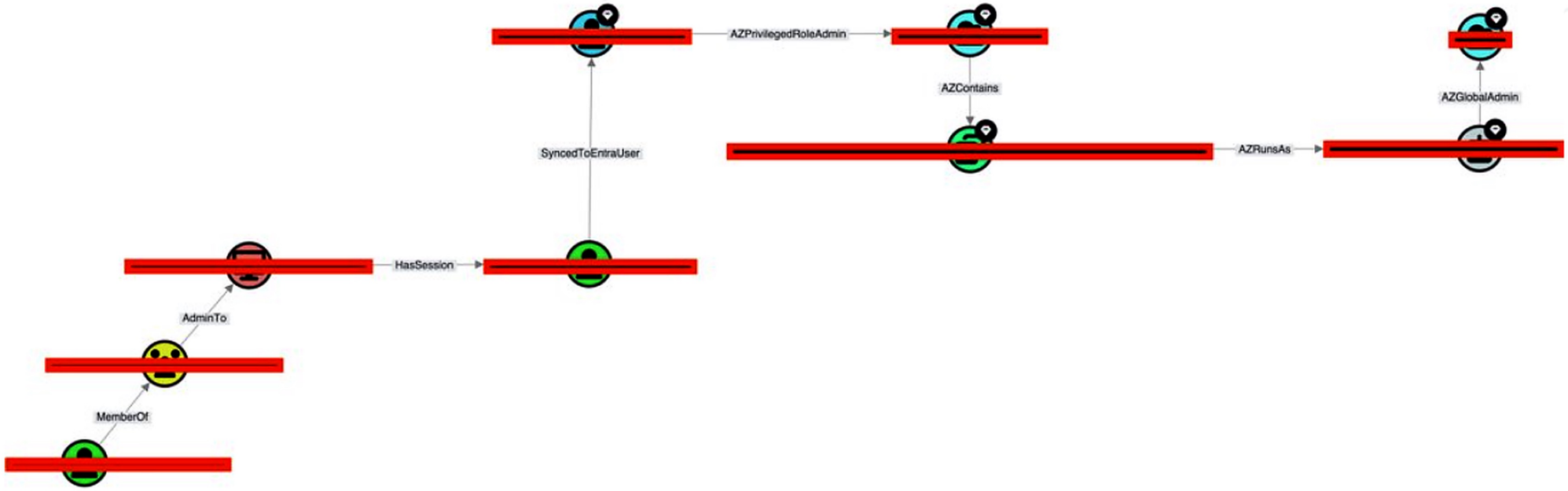
2 Years Ago: BloodHound visualizes hybrid MSFT Attack Paths



SPECTEROPS

© Specter Ops, Inc.

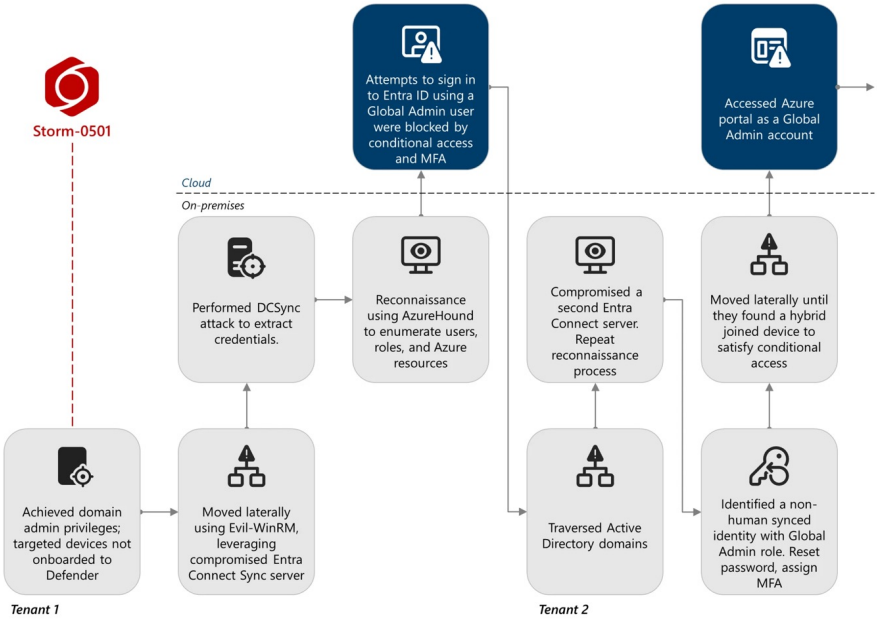
2 Years Ago: BloodHound visualizes hybrid MSFT Attack Paths



SPECTEROPS

© Specter Ops, Inc.

Storm-0501's evolving techniques lead to cloud-based ransomware



© Specter Ops, Inc.

From CI/CD to cloud compromise: Real-world breach using OpenID Connect abuse

Day 1
Initial Compromise

- Unknown threat group compromised the popular 'Nx' package
- Victim organization's developer updated existing NPM packages, including compromised 'Nx' package that executed malicious code
- QUIETVAULT malware obtained GitHub and NPM API keys from developer's workstation using AI that assisted with identifying files of interest
- QUIETVAULT malware uploaded API keys to public GitHub repository

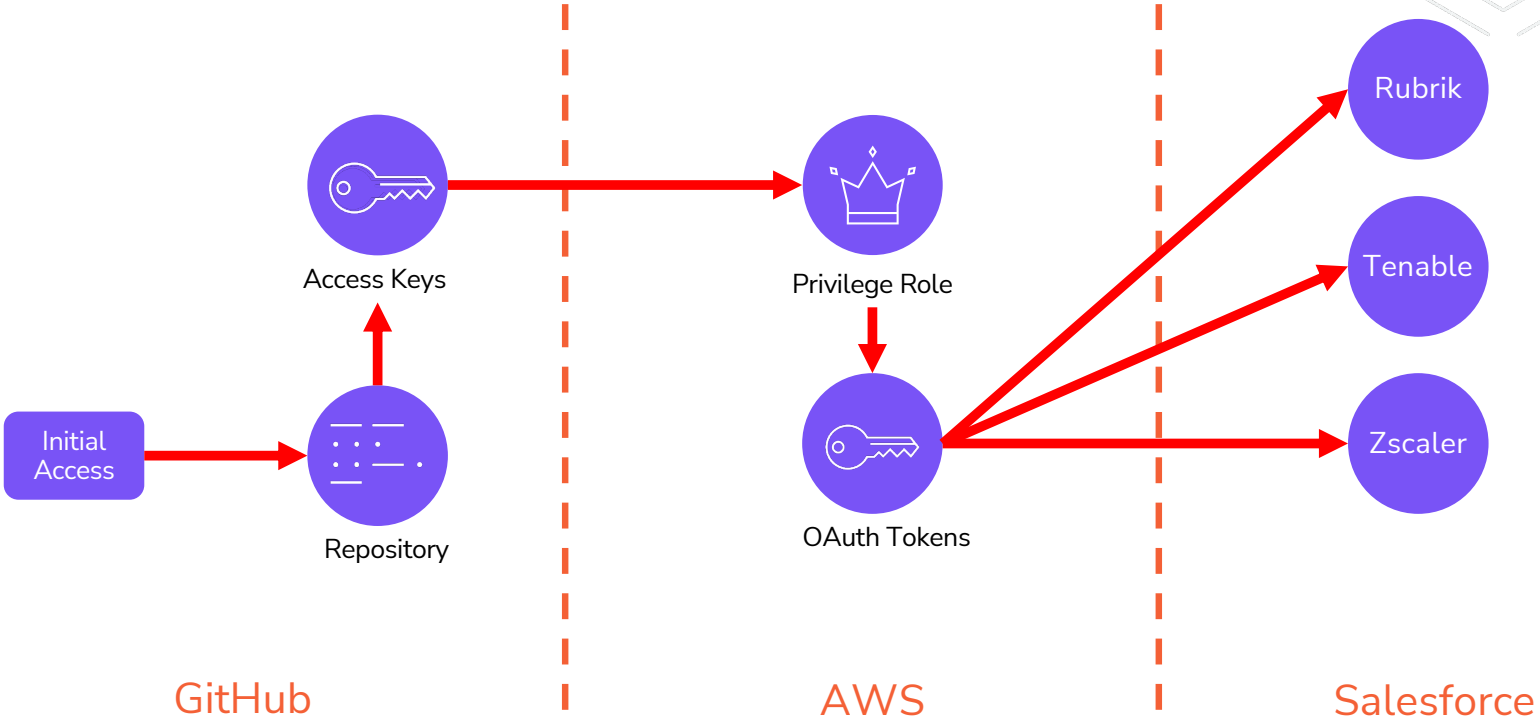
Day 3
Escalate Privilege

- UNC6426 accessed victim organization's GitHub repository using stolen keys
- UNC6426 enumerated victim organization's GitHub environment
- UNC6426 abused CI/CD pipeline, gaining access to AWS API keys

Day 4
Complete Objectives

- UNC6426 accessed victim organization's AWS environment and created unauthorized administrative credentials to escalate privileges
- UNC6426 exfiltrated data from victim organization's S3 buckets, renamed internal GitHub repositories and made them publicly accessible

SalesLoft Drift Breach Attack Path



Source: Widespread Data Theft Targets Salesforce Instances via Salesloft Drift

© Specter Ops, Inc.

Trivy Security Scanner GitHub Actions Breached, 75 Tags Hijacked to Steal CI/CD Secrets

"We identified that an attacker force-pushed 75 out of 76 version tags in the aquasecurity/trivy-action repository, the official GitHub Action for running Trivy vulnerability scans in CI/CD pipelines," Socket security researcher Philipp Burckhardt said. "These tags were modified to serve a malicious payload, **effectively turning trusted version references into a distribution mechanism for an infostealer**."

The payload executes within GitHub Actions runners and aims to **extract valuable developer secrets from CI/CD environments, such as SSH keys, credentials for cloud service providers, databases, Git, Docker configurations, Kubernetes tokens, and cryptocurrency wallets.**

© Specter Ops, Inc.

GitHub, Okta, and Jamf

Enterprise Extensions now in BloodHound Enterprise

SPECTEROPS

© Specter Ops, Inc.

Enterprise Extensions

- Automated Choke Point Analysis
- Prioritization and trend analysis
- Built-in Remediations
- Continuous monitoring & reconciliation
- Authored and supported by SpecterOps

Open-Source XHounds

- Authored and supported by the community
- Open-Source: Use at your own risk

SPECTEROPS

© Specter Ops, Inc.

Why we chose these first three

Top IDP for most organizations.

- *If we can control the IDP, we can get access anywhere.*

Used to manage macOS fleets

- *If we can control the management plane, we can control everything*

Holds source code, company IP

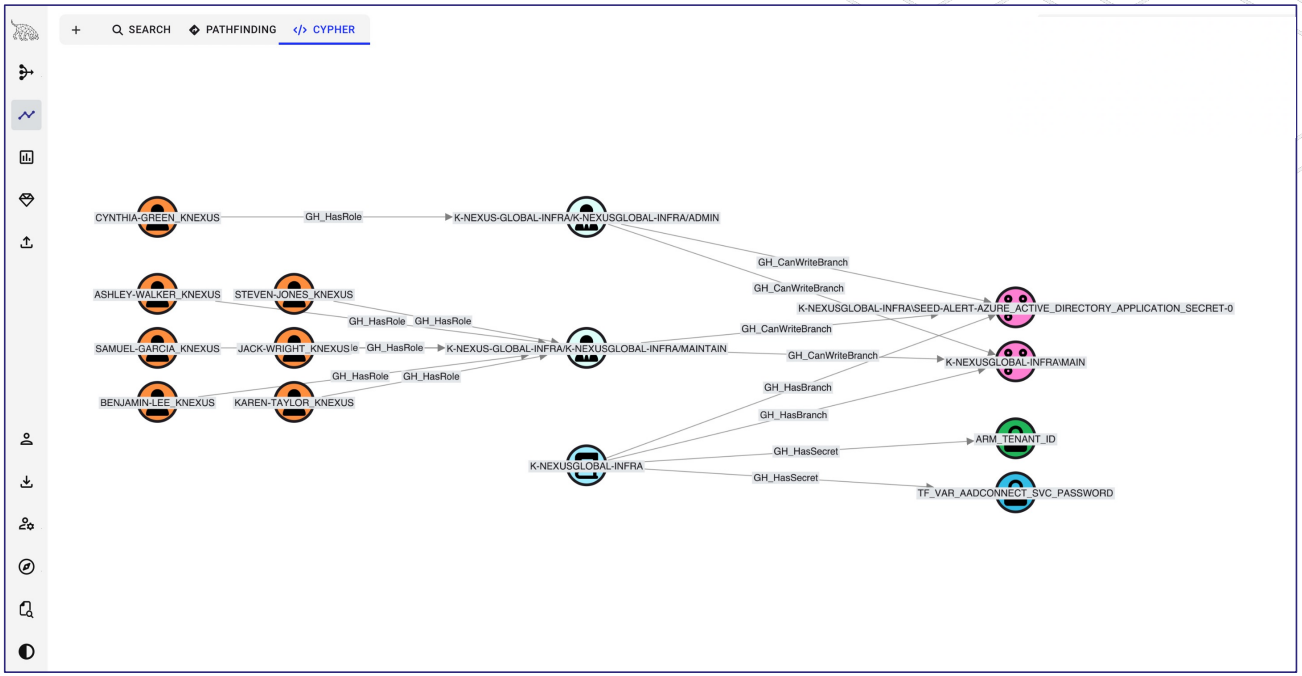
- *With access to GitHub, can we manipulate source code or steal IP*

© Specter Ops, Inc.

Attack Paths in GitHub with BloodHound Enterprise

GitHub

- Identity access to secrets
- Unprotected branches
- Risky branch protections
- Branch protection bypasses
- Self-approval workflows
- Public repos
- Privileged custom roles
- PAT access to all repos



Branch Protection Bypasses -> Secret Exfiltration

© Specter Ops, Inc.

Targeting Secret Scan Alerts in GitHub

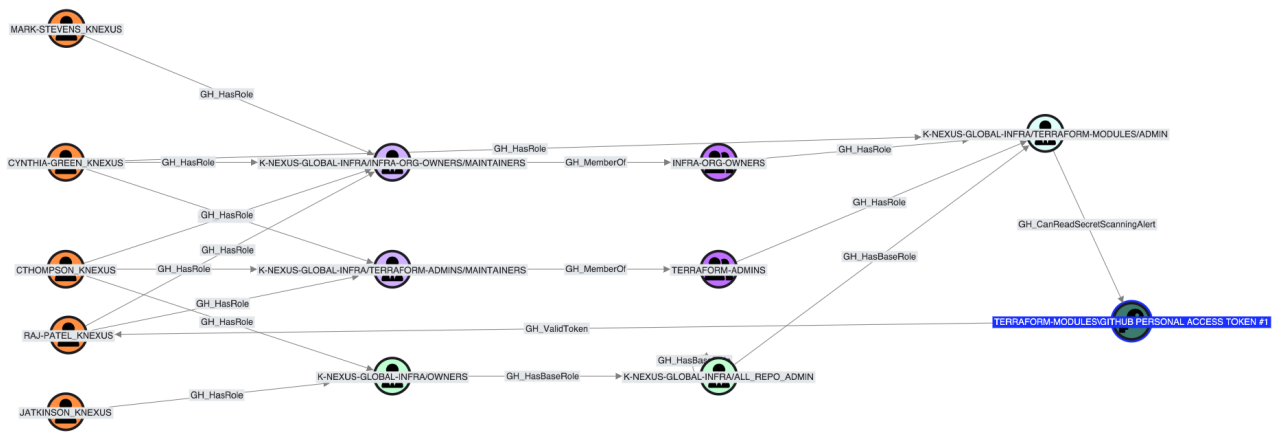
SEARCH | PATHFINDING | CYPHER

Saved Queries

Auto-run selected query

```
1 MATCH p=(role:GH_Role)-
  [:GH_HasRole|GH_HasBaseRole|GH_MemberOf|GH_ReadRepoCo
  ntents*1..]->(reporole:GH_Role)-
  [:GH_CanReadSecretScanningAlert]->
  (n:GH_SecretScanningAlert
  {objectid:'5353415F4F5F6B67444F445F575569415F525F6B67
  444F526C67324A675F31'})-[]->()
2 MATCH p1=(role)<-[:GH_HasRole]-(:GH_User)
3 OPTIONAL MATCH p2=(reporole)<-[:GH_HasRole]-
  (:GH_User)
4 RETURN p,p1,p2
```

Tag | Save | Run



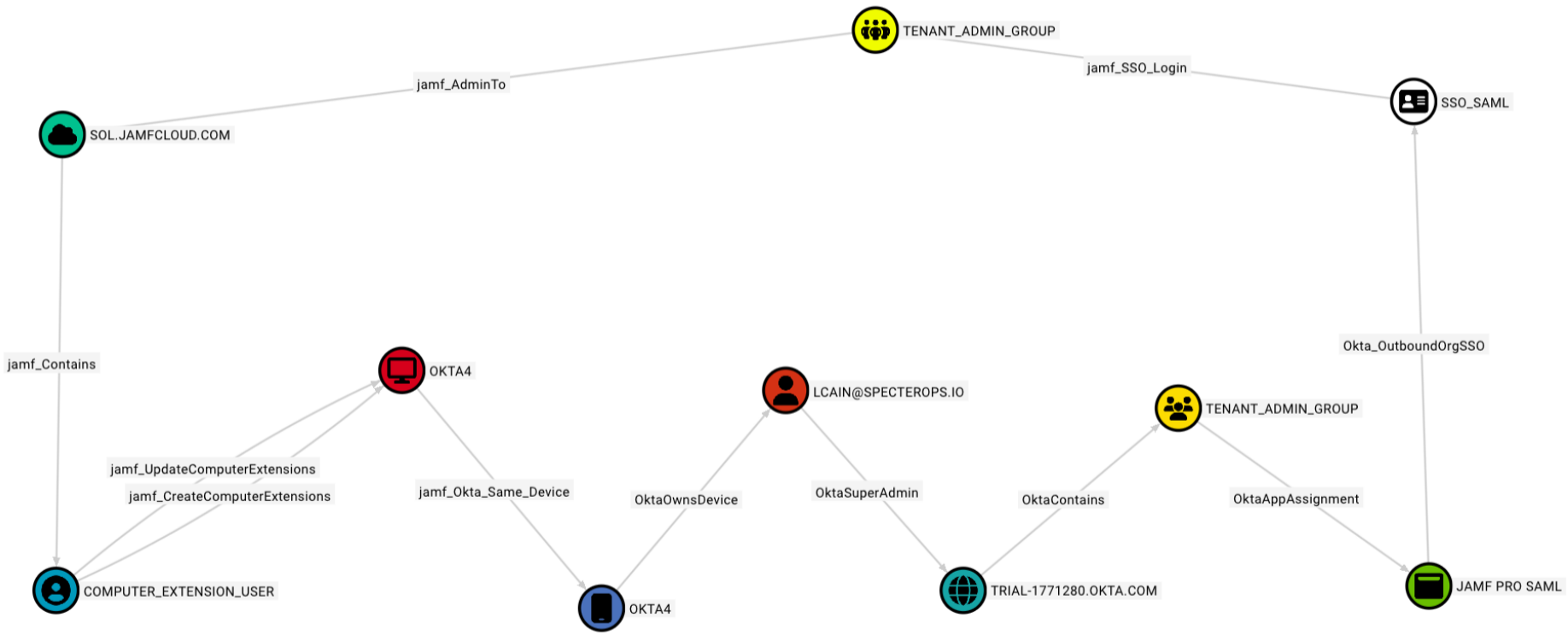
Hide Labels | Layout | Export | Search

TERRAFORM-MODULES\GITHUB PERSON...

Object Information

Node Type:	GH_SecretScanningAlert
Object ID:	5353415F4F5F6B67444F445F575569415F525F6B67444F526...
Created At:	2026-03-13T16:57:45Z
Environment Name:	k-nexus-global-infra
Environmentid:	4F5F6B67444F445F57556941
Last Seen by BloodHound:	2026-03-19 22:14 PDT (GMT-0700)
Node Id:	5353415F4F5F6B67444F445F575569415F525F6B67444F526...
Primary Kind:	GH_SecretScanningAlert
Query Alert Viewers:	MATCH p=(role:GH_Role)-[:GH_HasRole|GH_HasBaseRole|GH_MemberOf|GH_ViewSecre...>(:GH_Repository)-[:GH_Contains]->(:GH_SecretScanningAlert {node_id:'SSA_4F5F6B67444F445F57556941_525F6B67444F5... MATCH p1=(role)<-[:GH_HasRole]-(:GH_User) RETURN p,p1
Query Repository:	MATCH p=(r:GH_SecretScanningAlert {node_id:'SSA_4F5F6B67444F445F57556941_525F6B67444F5... <-[:GH_Contains]-(repo:GH_Repository) RETURN p
Repository Id:	R_kgDORlg2Jg
Repository Name:	terraform-modules
Repository Url:	https://github.com/k-nexus-global-infra/terraform-modules
Secret Type Display Name:	GitHub Personal Access Token
Secret Type:	github_personal_access_token
Secret:	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
State:	open
Updated At:	2026-03-13T19:21:05Z
Url:	https://github.com/k-nexus-global-infra/terraform-modules/security/secret-scanning/1
Validity:	active

macOS fleet compromise through okta & jamf



© Specter Ops, Inc.

Trivy breach from GitHub to AWS

© Specter Ops, Inc.

Attack Paths across platforms uncovers new problems

SPECTEROPS

© Specter Ops, Inc.

An Enterprise-wide call to action

The rise of the "Messy Middle"

- AD and Entra ID may be separate teams but likely sister organizations
- Who is responsible for the Attack Path that crosses from GitHub?

Laddering Privilege across Platforms

- Escalating Privilege through one platform may be impossible
- But pivoting back and forth to incrementally gain privilege is real

Clean-Source Principal

- "All security dependencies must be as trustworthy as the object being secured"

2:15 PM Monday
Hybrid Attacks and Identities in Motion: Anatomy of Modern Attack Paths
Elad Shamir VP of Research, SpecterOps
Will Schroeder Security Researcher, SpecterOps

© Specter Ops, Inc.

Key takeaways

1. You can’t secure what you can’t see
2. Every connection introduces risk
3. Attack Paths are inevitable, unmanaged ones are optional

© Specter Ops, Inc.

SPECTEROPS

Creators of BloodHound

Thank you

specterops.io

State of Identity Attack Path Management

© Specter Ops, Inc.